

HiveForce Labs

THREAT ADVISORY



VULNERABILITY REPORT

Dirty Frag A 2017 Optimization That Aged Into a Root Exploit

Date of Publication

May 12, 2026

Admiralty Code

A1

TA Number

TA2026126

Summary

First Seen: May 7, 2026

Affected Products: Linux kernel (xfrm-ESP and RxRPC subsystems)

Impact: A newly disclosed Linux local privilege escalation vulnerability known as “Dirty Frag” enables escalation from an unprivileged user to root through vulnerable kernel networking and memory-fragment handling components, including esp4, esp6 (CVE-2026-43284), and rxrpc (CVE-2026-43500). Public reporting and proof-of-concept activity indicate the exploit is designed to provide more reliable privilege escalation than traditional race-condition-dependent Linux local privilege escalation techniques. A pair of Linux kernel local privilege escalation vulnerabilities, collectively branded "Dirty Frag" (also tracked under the alias "CopyFail2"), was publicly disclosed on May 7, 2026, after a coordinated-disclosure embargo was broken ahead of upstream patch availability. Dirty Frag represents the second universal Linux kernel LPE class disclosed within eight days, following CVE-2026-31431 (Copy Fail). The vulnerability affects nearly every major Linux distribution because the underlying code paths shipped enabled by default since approximately 2017 (ESP) and 2023 (RxRPC), and no named threat actor has yet been publicly attributed to in-the-wild exploitation, though the public [PoC](#) and one-command exploitability mean any local foothold on an unpatched host should be assumed convertible to root.

⚙️ CVEs

CVE	NAME	AFFECTED PRODUCT	ZERO -DAY	CISA KEV	PATCH
CVE-2026-43284	Dirty Frag (Linux Kernel xfrm-ESP In-Place Decrypt Page-Cache Write Vulnerability)	Linux Kernel (xfrm-ESP / IPsec subsystem)	✗	✗	✓
CVE-2026-43500	Dirty Frag (Linux Kernel RxRPC In-Place Decrypt Page-Cache Write Vulnerability)	Linux Kernel (RxRPC subsystem)	✗	✗	✓

Vulnerability Details

#1

A newly disclosed Linux local privilege escalation vulnerability known as "Dirty Frag" enables escalation from an unprivileged user to root through vulnerable kernel networking and memory-fragment handling components, specifically the esp4 and esp6 modules (CVE-2026-43284) and the rxrpc module (CVE-2026-43500). Public reporting and proof-of-concept activity indicate that the exploit is designed to provide more reliable privilege escalation than traditional, race-condition-dependent Linux LPE techniques.

#2

The Dirty Frag chain exploits a shared design assumption in two unrelated Linux kernel subsystems, the xfrm Encapsulating Security Payload (ESP) path used by Ipsec, and the AF_RXRPC transport used by AFS clients, both of which adopted an in-place decryption optimization that omits a Copy-On-Write step under the belief that any non-cloned nonlinear socket buffer (skb) is privately owned by the kernel.

#3

When an attacker delivers a crafted packet that exploits this assumption, the kernel's ESP input handler takes the no-COW fast path for uncloned skbs without a frag_list and performs decryption in place over memory it does not actually own privately. With the attacker-chosen Security Parameters Index, cipher, and key supplied via AF_KEY or XFRM netlink, this produces a fully attacker-controlled "decrypted output" that is written directly into the page cache of the target binary. The RxRPC variant follows the same logic but reaches the in-place decryption fast path via AF_RXRPC sockets and add_key("rxrpc") registration of an attacker-controlled rxkad session key.

#4

The ESP code path was introduced in January 2017 by commit cac2661c53f3, which moved IPsec ESP receive into an in-place decryption fast path; the RxRPC variant was introduced in June 2023, when the same fast-path pattern was added. The long gap between vulnerability introduction and discovery, combined with the structural similarity to Copy Fail ([CVE-2026-31431](#)) disclosed one week earlier, suggests that AI-assisted code review may have surfaced both flaws.

#5

Risk evaluation should therefore rely on vendor-side assessments: AWS, Red Hat, SUSE, Ubuntu, Debian, AlmaLinux, and CloudLinux have all published advisories rating the chain as high-impact local privilege escalation with confirmed working, publicly available proof-of-concept code. No widespread in-the-wild exploitation campaigns have been publicly attributed to a named threat actor at the time of publication, but the trivial weaponization, deterministic reliability, and broad applicability place Dirty Frag firmly in the category of vulnerabilities that should be assumed exploitable on any unpatched local foothold.

Vulnerabilities

CVE ID	AFFECTED PRODUCTS	AFFECTED CPE	CWE ID
CVE-2026-43284	Linux kernel (xfrm-ESP / IPsec subsystem) kernel versions 4.10 through 7.0 (vulnerable code introduced January 2017 by commit cac2661c53f3)	cpe:2.3:o:linux:linux_kernel:*:*:*:*:*:*	CWE-123
CVE-2026-43500	Linux kernel (RxRPC subsystem) kernel versions 4.10 through 7.0 (vulnerable code introduced June 2023)	cpe:2.3:o:linux:linux_kernel:*:*:*:*:*:*	CWE-123

Recommendations



Apply the Patched Kernel for Your Distribution Immediately: Upgrade to the patched kernel published by your Linux distribution as soon as it reaches the production repository. AlmaLinux 9 should be at kernel-5.14.0-611.54.3.el9_7 or newer, AlmaLinux 10 at kernel-6.12.0-124.55.2.el10_1 or newer, CloudLinux 8 and 7 Hybrid at kernel-4.18.0-553.123.2.lve.el8 or newer, and Ubuntu, Debian, Red Hat, SUSE, and Oracle Linux customers should consult their respective vendor advisories for the corresponding patched build. Reboot is required for the new kernel to take effect, and customers using KernelCare livepatches can apply the relevant K20260508-prefixed patch identifier from May 8, 2026 or later for zero-downtime remediation.



Apply the Kernel Module Blacklist as an Interim Mitigation: On hosts where a patched kernel cannot be deployed immediately, blacklist the vulnerable modules and unload them if currently loaded by running the following command as root: `sh -c "printf 'install esp4 /bin/false\\ninstall esp6 /bin/false\\ninstall rxrpc /bin/false\\n' > /etc/modprobe.d/dirtyfrag.conf; rmmod esp4 esp6 rxrpc 2>/dev/null; true".` Regenerate the initramfs so the blacklist persists across early boot (sudo `update-initramfs -u -k all` on Debian/Ubuntu, or distribution-equivalent commands elsewhere). Do not apply this mitigation on hosts that terminate or transit IPsec, strongSwan, or Libreswan tunnels, or on AFS clients, without an alternative path planned, as the mitigation will break those services. Note that the mitigation will not be effective if the kernel was built with these features compiled directly into the kernel image rather than as loadable modules.



Flush the Page Cache After Mitigation on Potentially Targeted Hosts: Because the exploit modifies the in-memory page cache of legitimate system binaries to land its payload, applying the blacklist alone does not undo prior compromise. On any host where exploitation may have occurred before mitigation was in place, drop the page cache after applying the blacklist by running `sudo sh -c "echo 3 > /proc/sys/vm/drop_caches"` so that subsequent invocations re-read affected binaries from disk rather than from poisoned cached pages. Verify the integrity of high-value setuid binaries (`su`, `sudo`, `passwd`, `mount`, and similar) against trusted package-manager hashes before declaring the host clean.



Audit and Inventory Exposure Across the Estate: Identify exposed hosts by running `uname -r` to enumerate kernel versions and `lsmod | egrep '^(esp4|esp6|rxrpc)\\b'` (or `grep -qE '^(esp4|esp6|rxrpc) ' /proc/modules`) to verify whether the vulnerable modules are currently loaded. Catalogue legitimate IPsec terminators, AFS clients, and any workload requiring `CAP_NET_ADMIN` so that detection exceptions are narrowly scoped to known binaries rather than wholesale disabled. Confirm whether modules are available to load on demand even if not currently loaded, as the exploit can trigger autoload via the relevant `socket()` call.



Potential MITRE ATT&CK TTPs

Tactic	Technique	Sub-technique
Privilege Escalation	<u>T1068</u> : Exploitation for Privilege Escalation	
	<u>T1611</u> : Escape to Host	
Impact	<u>T1565</u> : Data Manipulation	<u>T1565.003</u> : Runtime Data Manipulation
Execution	<u>T1059</u> : Command and Scripting Interpreter	<u>T1059.004</u> : Unix Shell
Persistence	<u>T1546</u> : Event Triggered Execution	
Discovery	<u>T1082</u> : System Information Discovery	



Patch Links

<https://git.kernel.org/pub/scm/linux/kernel/git/stable/linux.git/commit/?id=8253aab4659ca16116b522203c2a6b18dccacea7>

<https://git.kernel.org/pub/scm/linux/kernel/git/stable/linux.git/commit/?id=d45179f8795222ce858770dc619abe51f9d24411>



References

<https://www.microsoft.com/en-us/security/blog/2026/05/08/active-attack-dirty-frag-linux-vulnerability-expands-post-compromise-risk/>

<https://blog.cloudlinux.com/dirty-frag-mitigation-and-kernel-update>

<https://github.com/V4bel/dirtyfrag>

<https://hivepro.com/threat-advisory/one-script-every-distro-full-root-copy-fail-vulnerability-rewriting-linux-threat-models/>



What Next?

At Hive Pro, it is our mission to detect the most likely threats to your organization and to help you prevent them from happening.

Book a Demo of HivePro.

REPORT GENERATED ON

May 12, 2026 • 03:30 AM

© 2026 All Rights are Reserved by Hive Pro



More at www.hivepro.com